INFORME TÉCNICO DE CONSULTORÍA

Esteganografía en Imágenes Radiológicas y Auditoría de Cifrado de Firmas Digitalizadas (CAI 2 – Parte 2)

Asignatura: Seguridad en Sistemas Informáticos y en Internet | **Equipo:** Security Team 2 (ST-2)
Autores: Raimundo García Pérez, Konstantinos Peridis, Luis Alarcón Conradi
Fecha: 27 de octubre de 2026 | **Código de entrega:** ST-2-CAI2B

Resumen Ejecutivo

A petición de la Dirección del Hospital, el equipo de SecurTech Advisory ha evaluado el uso de **esteganografía LSB** para insertar firmas ocultas en radiografías, ha realizado un **estegoanálisis forense** sobre una imagen sospechosa de fuga de información, y ha auditado la seguridad real del cifrado AES-256 aplicado a imágenes de firmas de médicos en un portátil sustraído. Los tres resultados principales son:

a) Método LSB:
Técnicamente viable para firmas de 128–512 caracteres (capacidad de sobra, imperceptible a nivel de señal: PSNR > 74 dB), pero **extremadamente frágil**: un simple 1% de ruido aleatorio ya corrompe el mensaje, y cualquier recorte que altere el ancho de la imagen también lo destruye, aunque conserve físicamente los píxeles del mensaje.

b) Estegoanálisis forense:
La imagen sospechosa (*Dibujo.bmp*) contenía realmente un mensaje oculto de 37.099 bytes —confirmado por dos métodos estadísticos independientes— que, al extraerlo, resultó ser un **plano de evacuación y extinción de incendios del edificio**: información de seguridad física filtrada de forma encubierta.

c) Cifrado AES-256 de las firmas sustraídas:
NO se puede dar por segura la información. Aunque la clave de 256 bits es inviable de romper por fuerza bruta, el fichero cifrado muestra la firma inequívoca del **modo de cifrado ECB**, que filtra el patrón visual del contenido original. Se ha logrado reconstruir el nombre, el NIF y la silueta de una firma manuscrita **sin descifrar nada y sin conocer la clave**.

1. Introducción y Objetivos

Esta consultoría es la continuación de CAI 2 – Parte 1 (cifrado de imágenes radiológicas y auditoría forense de VeraCrypt). Mientras aquella parte abordaba la **confidencialidad por cifrado**, esta Parte 2 aborda la **esteganografía**: ocultar información a simple vista dentro de imágenes, y detectarla cuando otros la usan. Se tratan tres consultas: (a) viabilidad del método LSB para firmar radiografías, (b) estegoanálisis forense de una imagen sospechosa de fuga de datos, y (c) seguridad real de imágenes de firmas de médicos cifradas con AES-256 en un equipo sustraído.

Entorno y herramientas: Virtual Steganographic Laboratory (VSL 1.1, Java 17), OpenSSL 3.5.3, y scripts propios en Python 3.10 (Pillow, NumPy, SciPy) para estegoanálisis estadístico independiente, distorsiones y auditoría de cifrado. Todos los scripts se adjuntan como anexos digitales junto a este informe.

2. Apartado a) — Estudio del Método LSB

2.1. Criterio 1: Tamaño de imagen necesario

Con 24 bits por píxel (3 bytes RGB), el método LSB dispone de 3 bits «libres» por píxel: capacidad (bytes) = ancho × alto × 3 / 8.

Firma	Lado mínimo imagen cuadrada	Capacidad real a ese tamaño
128 caracteres	19 × 19 px	135 bytes
512 caracteres	37 × 37 px	513 bytes
Imagen de prueba (512×512, generada)	—	98.304 bytes

Validación experimental: se ocultaron dos firmas reales (133 y 432 caracteres) en una imagen portadora de prueba (512×512 px, 786.486 bytes). En ambos casos el fichero resultante pesó **exactamente lo mismo** que el original, y la extracción posterior recuperó el mensaje **bit a bit idéntico** al original (verificado con *diff*).

> **Conclusión Criterio 1:**
> Cualquier radiografía real (cientos o miles de píxeles de lado) tiene capacidad de sobra para una firma de hasta 512 caracteres sin aumentar de tamaño. El tamaño de imagen nunca es el factor limitante.

2.2. Criterio 2: Confidencialidad

Versión	PSNR (dB)	Visible a simple vista	Detectable por bit-plane
Firma corta (133 c.)	79,54	No	No
Firma larga (432 c.)	74,57	No	No

El PSNR (relación señal/ruido de pico) mide numéricamente cuánto cambia la imagen; a partir de ~40 dB se considera imperceptible. Ambos valores obtenidos son muy superiores. El test estadístico de **Chi-cuadrado de Pares de Valores** (Westfeld-Pfitzmann), en cambio, **no fue fiable** en nuestra imagen de prueba: dio indicios de alteración incluso en la imagen original sin ningún mensaje, porque esta ya tenía ruido/textura de fondo alto (deliberadamente, para simular una radiografía real). Esto demuestra que ningún test estadístico aislado es fiable al 100% — conclusión que se confirma en el apartado b).

Mejora de confidencialidad propuesta y verificada: cifrar el mensaje con AES-256-CBC (enlazando con CAI 2 – Parte 1) antes de ocultarlo. Si alguien detecta y extrae los bits LSB sin conocer la clave, obtiene únicamente datos binarios ilegibles; con la clave correcta, el mensaje se recupera idéntico al original. Verificado experimentalmente con OpenSSL (`openssl enc -aes-256-cbc`).

2.3. Criterio 3: Robustez ante distorsiones

Distorsión aplicada	¿Mensaje recuperable?	Motivo técnico
Salt & Pepper 1%	No	Basta 1 píxel alterado de cada 100 para corromper bits del mensaje
Salt & Pepper 1%→5%→10%→20% (acumulado)	No (progresivamente peor)	Incluso la cabecera de longitud del mensaje se corrompe
Crop que excluye la zona del mensaje	No (falla directamente)	Los píxeles con el mensaje ya no existen en la imagen resultante

Crop que cambia el ANCHO (aunque conserve la esquina del mensaje)	No	LSB secuencial lee fila a fila según el ancho; al cambiar el ancho se desincroniza la lectura desde la 2ª fila
Crop que conserva el ancho completo	Sí, íntegro	El orden de lectura fila a fila coincide exactamente con el de la codificación

Conclusión Criterio 3 y mejoras propuestas:
El LSB secuencial simple es **extremadamente frágil**: no sobrevive ni al 1% de ruido ni a recortes que cambien la geometría de la imagen. Solo es adecuado si la imagen viaja intacta byte a byte (p. ej. en red interna sin recompresión), que es el escenario hospitalario descrito. Mejoras: (1) códigos de corrección de errores o repetición del mensaje para resistir ruido; (2) repartir el mensaje por toda la imagen, no solo al principio, para resistir recortes parciales; (3) si se prevé compresión o redimensionado, LSB no es viable y debe sustituirse por técnicas robustas en el dominio de la frecuencia (DCT, p. ej. F5).

3. Apartado b) — Estegoanálisis Forense

Se recibió *Dibujo.bmp* (338×338 px, 24 bits) como imagen sospechosa de contener información filtrada por un Jefe de Servicio. Siguiendo la recomendación del enunciado, se usó una herramienta **distinta de VSL** además de la propia VSL, para triangular resultados.

3.1. Metodología aplicada

Paso 1 – Estegoanálisis con VSL (LSB-RS, Fridrich): resultado «no message», con una estimación de 27.299 bytes. Este fue un **falso negativo**: el método RS pierde fiabilidad con tasas de ocultación muy altas, cercanas al límite de capacidad de la imagen.

Paso 2 – Estegoanálisis independiente (script Python propio, no VSL): comparación fila a fila entre el plano de bits menos significativo (LSB) y el inmediatamente superior (bit 1). En una imagen sin alterar ambos deberían coincidir; en las filas donde el LSB fue sobrescrito por un mensaje, la coincidencia cae a ~50% (ruido). Se detectó una transición neta en la fila 292 de 338, estimando **~37.011 bytes** ocultos.

Paso 3 – Intento de BSM-SVM (VSL): falló («*Could not load SVM model file*») porque ese módulo requiere un clasificador SVM pre-entrenado externamente que VSL no incluye por defecto; se documenta como limitación de la herramienta, no del análisis.

Paso 4 – Extracción (VSL, decoder LSB.D): confirmó un mensaje de **37.099 bytes**, en línea con la estimación independiente del Paso 2 (diferencia de solo 0,24%).

Método	Resultado	Estimación (bytes)
LSB-RS (VSL)	«no message» (falso negativo)	27.299 (descartado por el propio método)
Comparación de planos de bits (Python, propio)	Transición detectada en fila 292/338	37.011
Decoder LSB.D (VSL)	Mensaje extraído con éxito	37.099

3.2. Resultado de la extracción

El contenido extraído no era texto plano, sino un archivo **ZIP** (identificado por su cabecera estándar `50 4B 03 04`, «PK»), que al descomprimirse reveló una imagen JPEG. El contenido de esa imagen (ver Anexo I, confidencial) es un **plano de evacuación y extinción de incendios** del edificio, con rutas de salida y ubicación de extintores/mangueras —información de seguridad física, no datos de pacientes, pero igualmente sensible para la entidad si cae en manos ajenas.

Conclusión apartado b):
Se confirma la sospecha de la Dirección: la imagen contenía información filtrada de forma encubierta mediante esteganografía LSB, ocupando el 87% de la capacidad de la imagen. Recomendación: desplegar análisis RS/estadístico de forma rutinaria sobre imágenes salientes, combinando siempre varios métodos (uno solo, como se ha demostrado, puede dar falsos negativos).

4. Apartado c) — Seguridad del Cifrado AES-256 de las Firmas Sustraídas

Tras la sustracción de un portátil, se recuperaron 3 imágenes BMP con firmas escaneadas de médicos (nombre y NIF): *Firma2.bmp* y *Firma3.bmp* (descifradas) y *Firma1Cifrada.bmp* (cifrada con AES-256, clave de 32 caracteres aleatorios no almacenada en el equipo). Las tres imágenes comparten resolución 1280×800 px, 24 bits.

4.1. La clave es segura: cálculo de fuerza bruta

Extrapolando la metodología y velocidades reales medidas en CAI 1 – Parte 2 (hardware modesto, ~13,9 MH/s) a un espacio de claves de 256 bits ($2^{256} \approx 1{,}158 \times 10^{77}$ combinaciones):

Escenario	Tiempo estimado para romper la clave
1 CPU portátil (hardware real medido)	$2{,}64 \times 10^{62}$ años
Atacante 1.000 millones de veces más rápido (clúster GPU/ASIC hipotético extremo)	$2{,}64 \times 10^{53}$ años
Edad del universo (referencia)	$1{,}38 \times 10^{10}$ años

Incluso en el escenario más extremo planteado, el tiempo necesario sigue siendo **~$1{,}9 \times 10^{43}$ veces la edad del universo**. La clave de 256 bits, en sí misma, es completamente segura frente a fuerza bruta.

4.2. El verdadero problema: el modo de cifrado utilizado (ECB)

Se auditó *Firma1Cifrada.bmp* con un análisis de entropía y de repetición de bloques. Como control, se generaron datos verdaderamente aleatorios del mismo tamaño (`os.urandom`), que dieron una entropía de 7,9999 bits/byte (el máximo teórico es 8,0), como cabe esperar de un cifrado correcto. *Firma1Cifrada.bmp*, en cambio, dio solo **5,03 bits/byte**.

Analizando los 192.004 bloques de 16 bytes del fichero (16 bytes es el tamaño de bloque de AES), se encontró que **solo hay 6.817 bloques distintos**: un único patrón de 16 bytes se repite **153.043 veces (79,7% del fichero)**, y otro se repite 24.869 veces (12,9% más). Entre ambos suman el **92,6% del fichero completo**.

> **¿Por qué es esto tan grave?**
> En el modo de cifrado **ECB (Electronic Codebook)**, cada bloque de texto plano se cifra de forma independiente: bloques de entrada idénticos producen siempre el mismo bloque cifrado. Las imágenes de firma tienen enormes zonas de fondo blanco (píxeles idénticos repetidos cientos de miles de veces) —en modo CBC o GCM, esta repetición sería estadísticamente imposible de observar con esta frecuencia, porque cada bloque se combina con el cifrado del bloque anterior (o un contador/nonce único). La frecuencia observada es la firma inequívoca de ECB.

Para demostrarlo de forma concluyente, se reconstruyó una imagen asignando un tono de gris distinto a cada bloque cifrado distinto, respetando la geometría original de la imagen (1280×800 px). **El resultado revela el nombre, el NIF y la silueta de la firma manuscrita original, sin haber descifrado ni un solo byte y sin conocer la clave** (imagen completa en el Anexo II, confidencial, por contener datos personales reales).

4.3. Respuesta a la consulta y recomendaciones

> **¿Podemos estar tranquilos?**
> **No.** Aunque la clave de 256 bits es inquebrantable por fuerza bruta, el modo de cifrado empleado (ECB) **no proporciona confidencialidad real** para contenido con patrones repetitivos como estas imágenes. Un atacante no necesita romper la clave: le basta con analizar la repetición de bloques para reconstruir información identificativa y sensible (nombre, NIF, forma de la firma).

Medidas adicionales recomendadas:

1. **Cambiar el modo de cifrado**: nunca usar ECB; usar CBC con un IV aleatorio único por fichero, o preferiblemente un modo autenticado como **AES-GCM** (confidencialidad + integridad + detección de manipulación).
2. **Cifrado de disco completo** (BitLocker/LUKS) como segunda capa, para que ni siquiera el sistema de ficheros quede expuesto tras el robo.
3. **Gestión de claves en un gestor de secretos o HSM**, nunca en el propio equipo ni en texto plano.
4. **Borrado remoto (MDM)** para portátiles con datos sensibles, activable tras notificación de robo.
5. **Minimización de datos en endpoints**: las imágenes de firmas con NIF no deberían residir permanentemente en portátiles de campo, sino accederse bajo demanda desde un servidor central con control de acceso y registro de auditoría.

5. Conclusiones Globales

Esta consultoría demuestra que la seguridad de la información no depende de un único mecanismo, sino de la combinación correcta de técnicas y su aplicación rigurosa:

• **LSB es útil pero frágil**: adecuado para firmar imágenes en tránsito controlado dentro del hospital, pero no resiste procesado ni compresión; combinarlo con cifrado previo mejora la confidencialidad sin coste de tamaño.
• **Ningún método de estegoanálisis aislado es fiable**: el caso real analizado (Dibujo.bmp) habría pasado desapercibido si solo se hubiera confiado en LSB-RS; la combinación de métodos fue decisiva.
• **Una clave fuerte no implica un sistema seguro**: AES-256 con modo ECB es, en la práctica, tan débil frente a este tipo de contenido como un cifrado mucho más corto bien implementado. El **modo de operación** es tan importante como el tamaño de la clave.

Bibliografía

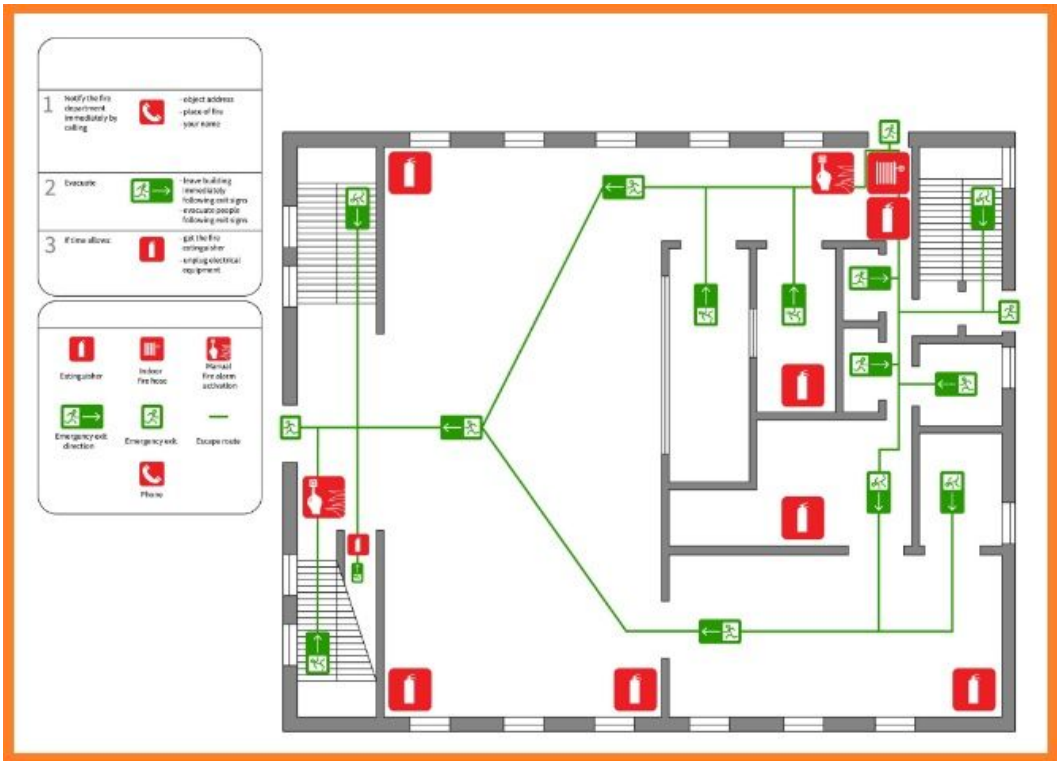
• Virtual Steganographic Laboratory (VSL) 1.1 – https://vsl.sourceforge.net/
• Fridrich, J., Goljan, M., Du, R. – *Reliable Detection of LSB Steganography in Color and Grayscale Images* (método RS).
• Westfeld, A., Pfitzmann, A. – *Attacks on Steganographic Systems* (Chi-cuadrado de Pares de Valores).
• NIST SP 800-38A – *Recommendation for Block Cipher Modes of Operation* (debilidades de ECB).
• Documentación oficial de OpenSSL 3.5 (`enc`).
• Informe previo del equipo: *CAI 2 – Parte 1, Informe Técnico de Cifrado y Auditoría Forense*, Security Team 2.

Relación de Anexos Entregados

• **Anexo I** (confidencial): plano de evacuación recuperado (apartado b) y hashes SHA-256.
• **Anexo II** (confidencial): imagen revelada por análisis de bloques ECB (apartado c), con nombre y NIF reales, y hashes SHA-256.
• Scripts Python: `estegoanalisis.py`, `localizar_mensaje2.py`, `confidencialidad.py`, `bitplane_propio.py`, `entropia.py`, `control_entropia.py`, `revelar_ecb.py`.
• Imágenes de prueba generadas y resultados intermedios (carpeta `trabajo/`).

ANEXO I (CONFIDENCIAL) — Mensaje Oculto Recuperado, Apartado b)

Contenido extraído de *Dibujo.bmp* mediante el decoder LSB.D de VSL. Se trata de un plano de evacuación y extinción de incendios del edificio hospitalario.



SHA-256 Dibujo.bmp (portadora original):
`1f06794a00b6a1b051abf0c3e5f462a3bced3459f6cb1a09a99e50c24d39831d`
SHA-256 payload ZIP extraído (LSB):
`8c1b0ddcfe99fa8b628d7c85e5b1055ad515c55f953db894f1526932c7e2bc11`
SHA-256 imagen recuperada (a5fde.jpg):
`acac67966db480e723f5642805a68dafb5f8fa661c43c52b8bb40bea6e83b9c3`

ANEXO II (CONFIDENCIAL) — Revelado por Análisis de Bloques ECB, Apartado c)

Reconstrucción visual de *Firma1Cifrada.bmp* a partir, exclusivamente, de la repetición de bloques cifrados de 16 bytes (sin descifrar ningún dato, sin conocer la clave AES). Se asigna un tono de gris distinto a cada bloque cifrado distinto, respetando la geometría 1280×800 de la imagen original.



Identidad revelada: Sara Barba Solís — NIF 34782082-H.

SHA-256 Firma1Cifrada.bmp:
`0e4d7664b1ba7ff0d91b8af73142c204815c64ecb40a9b97edd216e6a5663ecd`
Bloques de 16 bytes totales / distintos: 192.004 / 6.817
Bloque más repetido: 153.043 ocurrencias (79,7% del fichero)
Entropía Shannon del fichero: 5,03 bits/byte (control aleatorio de referencia: 7,9999 bits/byte)